Security Optimization Assessment — Defender for Office 365

Implementation Solution Guide

Version 1.0.0 · 2026-07-11

Contents

Executive Summary — Security Optimization Assessment: Defender for Office 365 4
- What you get . . . 4
- What this delivers . . . 4
- The standard deployment model . . . 5
- Outcome . . . 5
- Scope boundary . . . 5

1. Solution Overview — Security Optimization Assessment: Defender for Office 365 5
- What this assessment is . . . 5
- How Defender for Office 365 fits together (what we score) . . . 5
- How the score works . . . 6
- What's in scope . . . 6
- What's out of scope (be honest with buyers) . . . 6
- Authentication and connections used . . . 7
- The standard deployment model . . . 7

2. Requirements — Security Optimization Assessment: Defender for Office 365 7
- R1. Exchange Online Protection / Defender for Office 365 is in use . . . 7
- R2. Exchange Online and Security & Compliance PowerShell available (read-only) . . . 8
- R3. Read-only role that can read all threat policies and transport rules . . . 8
- R4. Graph read access for Secure Score and advanced hunting . . . 8
- R5. Defined recipient scope and the expected mailbox count . . . 8
- R6. A named best-practice baseline for scoring . . . 9
- R7. Secure destination for the findings report . . . 9

Global Requirements — Assessments (category-level) 9
- G1. The workload/tenant being assessed . . . 9
- G2. Read-only assessor access (least privilege) . . . 9
- G3. Microsoft Graph / Az / management API access . . . 10
- G4. Licensing for the products in scope . . . 10
- G5. Scope definition and a point-in-time baseline . . . 10
- G6. Best-practice reference baseline . . . 10
- G7. Output handling and confidentiality . . . 10
- G8. Remediation ownership (for the paired remediation) . . . 10

3. Implementation — Security Optimization Assessment: Defender for Office 365 11
- Stage 0 — Confirm scope and baseline (Assess) . . . 11
- Stage 1 — Establish read-only access (Assess) . . . 11
- Stage 2 — Validate the read (Pilot the read) . . . 11

Stage 3 — Discover every policy and rule (Assess) . . . 12
Stage 4 — Check coverage and bypass hygiene (Assess) . . . 12
Stage 5 — Score against best practice (Assess) . . . 12
Stage 6 — Generate the findings report (Validate → deliver) . . . 13
Stage 7 — Review and hand off (Expand) . . . 13
5. Testing — Security Optimization Assessment: Defender for Office 365 13
Gate 1 — Read-only access proven (run `SOAMDO-Validate.ps1`) . . . 13
Gate 2 — Discovery completeness (run `SOAMDO-Discovery.ps1`) . . . 13
Gate 3 — Effective-policy and coverage are real (run `SOAMDO-Coverage.ps1`) . . . 14
Gate 4 — Scoring is defensible (run `SOAMDO-Assess.ps1`) . . . 14
Gate 5 — Report reconciles with the portal (run `SOAMDO-Report.ps1`) . . . 14
Gate 6 — Repeatability (trend) . . . 14
6. Troubleshooting — Security Optimization Assessment: Defender for Office 365 14
`Connect-ExchangeOnline` or `Connect-IPPSSession` fails . . . 14
Transport rules or the Tenant Allow/Block List come back empty . . . 15
An MDO-only policy type is empty (Safe Links / Safe Attachments / impersonation) . . . 15
Coverage says a recipient is "uncovered" but a policy clearly exists . . . 15
Advanced-hunting `EmailEvents` query is empty or times out . . . 15
Scorecard marks a deliberately allow-listed vendor as a finding . . . 15
Report findings don't match the portal on spot-check (Gate 5 fail) . . . 16
Validate flags a write capability present . . . 16
7. Best Practices — Security Optimization Assessment: Defender for Office 365 16
Keep it strictly read-only . . . 16
Hunt the bypasses — they are the highest-value findings . . . 16
Score the effective policy, not the intent . . . 17
Make the numbers defensible . . . 17
Hand off well . . . 17
Protect the output . . . 17
Where to go next (adjacent catalog areas) . . . 17
8. Deliverables Summary — Security Optimization Assessment: Defender for Office 365 18
Documentation . . . 18
Automation artifacts (all read-only) . . . 18
What the buyer receives . . . 19
Outcome . . . 19
Appendix A — PowerShell Scripts 21

Executive Summary — Security Optimization Assessment: Defender for Office 365

White-label · Assessments

Defender for Office 365 (MDO) is usually "on" the moment the licenses land — but "on" and "tuned" are very different things. The default policies catch a lot, yet the questions that decide whether email is actually well-protected go unanswered: are **anti-phishing** policies configured with impersonation and spoof protection, is **Safe Links** rewriting and detonating URLs (including inside Office apps and Teams), is **Safe Attachments** detonating in **Block** mode, are you using the **preset security policies** or a drift-prone tangle of custom ones — and, most dangerously, **who has been quietly excused** from protection by allow-list entries, mail-flow (transport) rules, and bypass exceptions. A deployed product is not an optimized one, and email is still the number-one way in.

This solution is a **read-only Security Optimization Assessment**. It discovers your MDO / Exchange Online Protection configuration, **scores it against Microsoft best practice**, and produces a **prioritized, risk-ranked findings report** — anti-phish / Safe Links / Safe Attachments posture, preset-policy usage, **override & bypass hygiene**, and threat coverage — so you know, with evidence, exactly what to fix and in what order. It **changes nothing**: every command is a read-only `Get-`/read scope, and the only outputs are a scorecard and a findings report.

This is a complete, **run-it-today** package written for an administrator who has opened the Defender portal but has never pulled every EOP/MDO policy with PowerShell, mapped which recipients each policy actually covers, or enumerated the transport rules and allow-list entries that silently bypass filtering.

What you get

- A plain-language **Solution Overview** — what MDO's protections are (anti-spam, anti-malware, anti-phish, Safe Links, Safe Attachments, preset policies, the Tenant Allow/Block List, and transport-rule interactions), what "good" looks like, and how a read-only assessment turns that into a score.
- A **Requirements Guide** with verify / implement-if-missing for every solution-specific prerequisite (category-wide ones live in **Global Requirements — Assessments**).
- An **Implementation Guide** of precise, ordered steps — validate read access, discover every policy and rule, check recipient coverage and bypass hygiene, score, generate the findings report, review, then re-run to trend.
- Five read-only automation artifacts: a **Discovery** script, an **Assess/score** script, a **per-area Coverage** check, a **Findings Report** generator (HTML + CSV), and an access **Validate** self-check.
- **Testing** and **Troubleshooting** guides so a first run goes cleanly.

What this delivers

A defensible, point-in-time **posture score** for Defender for Office 365 plus a **prioritized remediation backlog**: which protections are weak or off, which recipients are uncovered, which policy is actually "effective" when several apply, and — high on the list — **every override and bypass** (allow-list entries, transport-rule exceptions, disabled protections) that quietly weakens filtering, each finding tagged with a

severity and a fix pointer.

The standard deployment model

Assess → **Configure** → **Pilot** → **Validate** → **Expand** — this product owns the **Assess** stage. The scripts are strictly read-only; **risk-acceptance and remediation priority are the customer's security owners' decisions**, and the fixes are pilot-first work delivered by the paired **Remediation Playbook**. Licensing, plan, and preview facts are flagged **verify** because they change.

Outcome

You stop assuming email is protected because MDO is licensed. You get a scored picture and an ordered backlog — including the bypasses nobody remembered — the evidence to fix what matters, in the right order, and a repeatable way to re-score.

Scope boundary

This is an **assessment** — it observes, scores, and reports; it does **not** change policies and it does **not** deploy or tune MDO. The fixes are the paired **Remediation Playbook** (pilot-first). Building EOP/MDO hygiene, unified Defender onboarding, threat hunting, and SOC operations are the existing **DEFMDOP2**, **DEFXDR**, **THREATHUNT**, and **SOCXDR** catalog areas — this assessment cross-references them for the remediation path rather than duplicating them.

1. Solution Overview — Security Optimization Assessment: Defender for Office 365

What this assessment is

This solution is a **read-only Security Optimization Assessment** for **Microsoft Defender for Office 365 (MDO)** and the underlying **Exchange Online Protection (EOP)**. It does not change any policy. It **discovers** how email protection is configured, **scores** it against Microsoft best practice, and produces a **prioritized, risk-ranked findings report**. The deliverable is *evidence and a plan*; the fixes are a separate, pilot-first exercise (the paired **Remediation Playbook**).

The problem it solves is the gap between *licensed* and *tuned*. MDO applies useful defaults, but defaults are not a tuned posture — and, crucially, protection can be **silently weakened** over time by allow-list entries, mail-flow (transport) rules that skip filtering, and disabled controls that no one revisits. This assessment reads all of it and tells you where you actually stand.

How Defender for Office 365 fits together (what we score)

- **Anti-spam (hosted content filter).** Spam/bulk/phish confidence thresholds, allowed/blocked senders and domains, and the outbound spam policy. Over-broad allow lists here are a classic self-inflicted gap.
- **Anti-malware.** The common-attachments filter and zero-hour auto purge (ZAP) for malware.
- **Anti-phishing.** Spoof intelligence, **user and domain impersonation protection**, mailbox intelligence, and the action taken on detected phish. *Impersonation protection (protected

users/domains) is a Defender for Office 365 Plan feature — verify your plan.*

• **Safe Links.** Time-of-click URL rewriting and detonation, including coverage **inside Office apps, Teams, and email**, and whether users can click through warnings. Off or partial Safe Links is a coverage finding.

• **Safe Attachments.** Detonation of attachments in a sandbox, the **action** (Block / Monitor / Dynamic Delivery), and Safe Attachments for SharePoint/OneDrive/Teams. **Monitor** (not Block) is a common false-comfort setting.

• **Preset security policies.** Microsoft's **Standard** and **Strict** preset policies apply recommended settings that Microsoft keeps current. Using presets vs. a sprawl of custom policies is itself a hygiene signal; *preset scope and behavior evolve — verify current guidance.*

• **Policy precedence & effective policy.** When several policies of a type exist, **priority** and recipient scope decide which one actually applies to a given user. "A strict policy exists" means nothing if it does not cover the right recipients or is outranked.

• **Override & bypass hygiene.** The **Tenant Allow/Block List**, per-policy allowed senders/domains, **transport rules** that set SCL -1 or skip filtering, IP allow lists in the connection filter, and any disabled protection. *These are the highest-value findings because they are invisible in day-to-day use.*

• **Threat coverage signals.** Post-delivery events and the volume of mail that bypassed filtering (via advanced hunting `EmailEvents`), plus MDO-related Secure Score recommendations, to rank findings by real risk.

How the score works

Each area yields **checks** with a best-practice expectation (from the baseline named in the report — Microsoft **preset Standard/Strict** and Secure Score, *verify current guidance*). Every check is **Pass / Partial / Fail / N-A**, and every non-pass becomes a **finding** with a **severity** (High / Medium / Low), the **evidence**, and a **remediation pointer**. Areas roll up into a **posture score (%)** you can trend. The score measures; **which findings to accept, defer, or fix, and in what order, is your security owners' decision.**

What's in scope

• Read-only **discovery** of every EOP/MDO policy and rule: anti-spam, anti-malware, anti-phish, Safe Links, Safe Attachments, preset policies, connection filter, outbound spam, and DKIM.

• **Recipient coverage** analysis — which users each policy actually covers, and who is covered by nothing / by weak policy.

• **Override & bypass** enumeration — Tenant Allow/Block List, per-policy allow lists, transport-rule filtering bypasses, IP allow lists, disabled protections.

• **Scoring** against preset Standard/Strict + Secure Score, producing per-check Pass/Partial/Fail.

• A **findings report** (HTML + CSV) with severities, evidence, and remediation pointers.

What's out of scope (be honest with buyers)

• **No changes.** This never edits a policy, removes an allow-list entry, or disables a transport rule. Fixing findings is the paired **Remediation Playbook** (pilot-first).

• **Not an EOP/MDO build or hardening project.** Standing up and hardening email protection is the **DEFMDOP2** area. This assesses what exists.

• **Not threat hunting or IR.** Live hunting and incident response are **THREATHUNT** / **SOCXDR**. This reads posture, not live threats. *IR determinations belong to the SOC.*

• **Not a licensing purchase.** We *read* plan state and flag gaps as findings; buying/mapping plans is separate. *Plan/feature mapping changes — verify.*

• **No risk-acceptance decision.** The assessment supplies the score and evidence; accepting or prioritizing risk is the customer's.

Authentication and connections used

• **Exchange Online PowerShell** (`Connect-ExchangeOnline`) and **Security & Compliance PowerShell** (`Connect-IPPSSession`) signed in as **Global Reader** / **Security Reader** / **View-Only Configuration** — all MDO/EOP policy reads use `Get-` cmdlets only (per Global Requirements G2). *Verify current read-role coverage for these cmdlets.*

• **Microsoft Graph (read-only)** for **Secure Score** MDO recommendations and **advanced hunting** (`EmailEvents`, `EmailPostDeliveryEvents`) via `AdvancedHunting.Read.All`. *Verify current scope names.*

• No write scopes are ever requested; `SOAMDO-Validate.ps1` fails if any are present.

The standard deployment model

> ***Assess the current email-protection configuration (discovery) → configure nothing; score and rank instead → pilot the read against a representative recipient scope → validate read-only access and that the effective-policy math reconciles with the portal's configuration analyzer → expand to the whole tenant, deliver the findings report, and re-run periodically to trend.*** *The repeatable pattern is* ***Assess → Configure → Pilot → Validate → Expand****; this product owns* ***Assess****, and the fixes are the Remediation Playbook's, pilot-first.*

2. Requirements — Security Optimization Assessment: Defender for Office 365

The category-wide prerequisites (target tenant, least-privilege read-only access, Graph/management API access, licensing awareness, defined scope and point-in-time baseline, the best-practice reference, secure output handling, and remediation ownership) are in the separate **Global Requirements — Assessments** file — read it first and do not repeat those here. Below are only the prerequisites **specific to assessing Defender for Office 365**. Each item: **Description / Why required / How to verify / How to implement if missing.**

R1. Exchange Online Protection / Defender for Office 365 is in use

Description: The tenant uses Exchange Online with EOP, and (for the MDO-specific checks) has Defender for Office 365 licensing on at least some mailboxes. **Why required:** The assessment reads existing email-protection policies; a tenant not using Exchange Online has nothing to assess, and MDO-only checks are N-A without the plan. **How to verify:** Sign in to `security.microsoft.com` → **Email & collaboration** → **Policies & rules** → **Threat policies**; confirm the policy set loads. Confirm MDO licensing in the admin center. *Verify current plan/feature mapping.* **How to implement if missing:** If MDO is not licensed, EOP-only checks still apply and MDO-only checks are scored **N-A** (a coverage finding). Building/hardening protection is the **DEFMDOP2** solution.

R2. Exchange Online and Security & Compliance PowerShell available (read-only)

Description: The **ExchangeOnlineManagement** PowerShell module, and the ability to run `Connect-ExchangeOnline` and `Connect-IPPSSession` with a read-only role. **Why required:** Every MDO/EOP policy read is a `Get-` cmdlet in these endpoints; there is no complete Graph equivalent today. *Verify current API coverage.* **How to verify:** `Get-Module ExchangeOnlineManagement -ListAvailable` returns a version; `Connect-ExchangeOnline` succeeds; `Get-AntiPhishPolicy | Select -First 1` returns. **How to implement if missing:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser`. Assign **Global Reader** / **Security Reader** / **View-Only Configuration** to the assessor.

R3. Read-only role that can read all threat policies and transport rules

Description: A role sufficient to read anti-spam/malware/phish, Safe Links, Safe Attachments, preset policies, the connection filter, the **Tenant Allow/Block List**, and **transport (mail-flow) rules**. **Why required:** The bypass-hygiene checks depend on reading transport rules and allow lists; a role missing these produces a falsely "clean" report. **How to verify:** Run `SOAMDO-Validate.ps1` — it confirms it can read a policy of each type **and** transport rules and the Tenant Allow/Block List. **How to implement if missing:** Ensure the read-only role includes mail-flow and organization configuration read. **Global Reader** generally covers these reads; *verify current role-to-cmdlet mapping.*

R4. Graph read access for Secure Score and advanced hunting

Description: Microsoft Graph read scopes for **Secure Score** (`SecurityEvents.Read.All`) and **advanced hunting** (`AdvancedHunting.Read.All`) over `EmailEvents` / `EmailPostDeliveryEvents`. **Why required:** Threat-coverage ranking uses how much mail bypassed filtering and post-delivery events; Secure Score provides the MDO recommendation signal. **How to verify:** In `security.microsoft.com` → **Advanced hunting**, run `EmailEvents | take 1`. `Connect-MgGraph` with the read scopes succeeds. **How to implement if missing:** Consent the read scopes (or the read-only app registration). *Verify current scope names and hunting retention.*

R5. Defined recipient scope and the expected mailbox count

Description: A documented definition of which recipients are in scope and the **expected** mailbox count from an authoritative source, so "coverage" has a real denominator. **Why required:** "A strict policy exists" is meaningless without knowing whether it covers the right recipients; coverage needs the full mailbox population. **How to verify:** You have the mailbox count/scope (e.g. from `Get-Mailbox` count or the

admin center) to compare policy recipient coverage against. **How to implement if missing:** Capture the mailbox scope before the run; `SOAMDO-Coverage.ps1` uses it to find recipients covered by nothing or by weak policy.

R6. A named best-practice baseline for scoring

Description: The reference the score is measured against — Microsoft's **preset Standard/Strict** security policy settings and **Secure Score** MDO recommendations, and/or the org standard. **Why required:** A score is only meaningful against a stated reference; the report names it so results are defensible and comparable. **How to verify:** The baseline is documented in scope and echoed in the report header. *Preset behavior evolves — verify against current Microsoft guidance at run time.* **How to implement if missing:** Adopt **preset Strict** (or Standard) + Secure Score as the default reference; note deliberate deviations as accepted exceptions rather than findings.

R7. Secure destination for the findings report

Description: A restricted location for the HTML/CSV output, which lists exactly which recipients are under-protected and which bypasses exist. **Why required:** The report is a phishing roadmap for anyone who obtains it; it must be handled as sensitive. **How to verify:** A need-to-know location exists and access is limited to the security owners. **How to implement if missing:** Provision a restricted location before the run; treat output as confidential. *Risk-acceptance of any finding is the customer's decision.*

Global Requirements — Assessments (category-level)

These requirements apply to every solution in the Assessments category (Security Optimization Assessments, remediation playbooks, and cross-cutting security assessments). Published once at the category level so listings stay small. Confirm these before running any assessment. Each entry: Description / Why / Verify / Implement-if-missing.

> *An assessment observes and scores; it does not change your tenant. Every assessment script here is **read-only** (the paired remediation work is separate and pilot-first). Scope, risk-acceptance, and remediation-priority decisions belong to the customer's security/compliance owners — the assessment supplies the evidence, not the authorization.*

G1. The workload/tenant being assessed

Description: An active Microsoft 365 / Entra tenant and/or Azure subscription(s) hosting the products in scope. Why: There is nothing to assess without the target environment. Verify: Sign in to the relevant portal(s) (`security.microsoft.com`, `portal.azure.com`) as an administrator. Implement: Ensure the target tenant/subscription exists and the products under assessment are deployed (even partially — assessing coverage gaps is the point).

G2. Read-only assessor access (least privilege)

Description: A read-only role sufficient to enumerate configuration — e.g. Security Reader, Global Reader, and/or Reader at the Azure scope. Why: An assessment must never require write access; read-only proves it changes nothing. Verify: Entra -> `Roles and administrators`; confirm Security Reader / Global Reader (and Azure Reader where cloud resources are assessed). Implement: Assign the read-only

roles; do not grant write/admin roles for the assessment itself.

G3. Microsoft Graph / Az / management API access

Description: Microsoft Graph (Security), Azure Resource Manager, and product-specific management APIs reachable with the assessor identity. Why: The assessment scripts collect configuration and posture via these APIs. Verify: `Connect-MgGraph` (read scopes) and `Connect-AzAccount` succeed; the assessment discovery script runs. *Verify current API/permission scopes.* Implement: Consent the read-only Graph scopes; ensure network access to the Microsoft endpoints.

G4. Licensing for the products in scope

Description: The licenses/plans for the products being assessed (e.g. Defender for Endpoint/Identity/Office 365/Cloud Apps plans, Defender for Cloud plans). Why: Some posture/configuration is only present (and only assessable) when the plan is enabled; the assessment flags plan gaps too. Verify: Confirm the relevant plans in the admin/billing portal. *Verify current plan/feature mapping.* Implement: Note unlicensed products as findings (a coverage gap) rather than skipping them silently.

G5. Scope definition and a point-in-time baseline

Description: A defined assessment scope (which products, subscriptions, and users) and the understanding that results are a point-in-time snapshot. Why: Scope keeps the assessment bounded and the score comparable; posture drifts, so results are dated. Verify: The scope is documented; the assessment records the run date. Implement: Agree the scope before running; re-run periodically to trend the score.

G6. Best-practice reference baseline

Description: The best-practice / benchmark the assessment scores against (Microsoft security baselines, Secure Score, CIS/Zero-Trust as applicable). Why: A score is only meaningful against a reference; the assessment states which baseline it uses. Verify: The reference baseline is named in the findings. *Baselines evolve — verify against current Microsoft guidance.* Implement: Use the documented baseline; note where organizational policy intentionally deviates.

G7. Output handling and confidentiality

Description: A place to store the findings report and an understanding that it may contain sensitive posture detail. Why: Assessment output is a roadmap of your weaknesses; it must be handled as sensitive. Verify: A secure destination for the report exists; access is restricted. Implement: Store findings securely; share on a need-to-know basis. *Risk-acceptance of any finding is the customer's decision.*

G8. Remediation ownership (for the paired remediation)

Description: Named owners for acting on findings (the remediation is separate, pilot-first work). Why: An assessment only creates value when someone owns closing the gaps. Verify: Remediation owners are identified; the Remediation Playbook solution is available for the fixes. Implement: Assign owners; use the Remediation Playbook (pilot-first, -WhatIf-gated) to close findings and re-score.

The deployment model (all solutions): Assess -> Configure -> Pilot -> Validate -> Expand.

3. Implementation — Security Optimization Assessment: Defender for Office 365

This is the exact, ordered procedure to run the assessment end to end. It is **read-only** throughout — you edit no policy and remove no allow-list entry; the only artifacts you create are an assessor identity, a scope file, and the output report. Follow the steps in order and reuse the exact object names below in later steps, testing, and troubleshooting.

Naming convention — every object you create uses `<Purpose> – <Scope> – <Stage>`:

Object	Name to use
Read-only app registration (optional, for unattended Graph reads)	`SOA-MDO-Reader – Tenant – Assess`
Scope definition file	`SOAMDO-Scope – Tenant – Assess.json`
Output run folder	`SOAMDO-Run – <yyyy-mm-dd> – Assess`
Scorecard (CSV)	`SOAMDO-Scorecard – Tenant – Assess.csv`
Findings report (HTML)	`SOAMDO-Findings – Tenant – Assess.html`

Stage 0 — Confirm scope and baseline (Assess)

1. Agree the **in-scope recipient population** with the owner and record the **expected mailbox count** from an authoritative source (R5).

2. Record the **baseline** — preset **Strict** or **Standard** + Secure Score MDO recommendations, and any org standard (R6). *Verify against current Microsoft guidance at run time.*

3. Create `SOAMDO-Scope – Tenant – Assess.json` capturing: scope description, expected mailbox count, chosen preset baseline (Standard/Strict), and run date.

Stage 1 — Establish read-only access (Assess)

1. In `security.microsoft.com` (or Entra → Roles), confirm the assessor holds **Global Reader** / **Security Reader** / **View-Only Configuration** — enough to read every threat policy, transport rules, and the Tenant Allow/Block List (R3). Grant **no** write role.

2. **(Optional, for unattended Graph reads)** create the `SOA-MDO-Reader – Tenant – Assess` app registration with **read-only** Graph permissions (`SecurityEvents.Read.All`, `AdvancedHunting.Read.All`) and admin-consent. Add **no** write permissions.

3. Install/confirm modules (R2): `Install-Module ExchangeOnlineManagement -Scope CurrentUser`. Confirm `Connect-ExchangeOnline` and `Connect-IPPSSession` succeed with the assessor.

Stage 2 — Validate the read (Pilot the read)

1. Run `SOAMDO-Validate.ps1`. It confirms the identity can read (a) an anti-phish, Safe Links, Safe Attachments, anti-spam and anti-malware policy, (b) the **preset** policy rules, (c) **transport rules** and the **Tenant Allow/Block List**, and (d) a Graph advanced-hunting query — and asserts **no write scope/role** is present. Fix any gap before continuing.

2. Confirm the policy counts reported reconcile with **Threat policies** in the portal.

Stage 3 — Discover every policy and rule (Assess)

1. Create the run folder `SOAMDO-Run – <yyyy-mm-dd> – Assess` (R7, restricted).

2. Run `SOAMDO-Discovery.ps1 -ScopeFile "SOAMDO-Scope – Tenant – Assess.json" -OutputDir "SOAMDO-Run – <yyyy-mm-dd> – Assess"`. It collects, read-only:

• anti-spam (hosted content filter) policies + rules, and the **outbound** spam policy;

• anti-malware policies;

• **anti-phish** policies (impersonation/spoof settings);

• **Safe Links** and **Safe Attachments** policies + rules;

• **preset** security policy rules (EOP + ATP protection policy rules) and their state;

• the **connection filter** (IP allow/block) and **DKIM** config;

• **transport (mail-flow) rules** and the **Tenant Allow/Block List** (for bypass hygiene);

• Secure Score MDO recommendations and advanced-hunting `EmailEvents` volume signals.

All written to the run folder as JSON/CSV. Nothing is changed.

Stage 4 — Check coverage and bypass hygiene (Assess)

1. Run `SOAMDO-Coverage.ps1 -InputDir "SOAMDO-Run – <yyyy-mm-dd> – Assess" -ExpectedMailboxCount <n>`. It computes:

• **Protection coverage** — which recipients are covered by an anti-phish / Safe Links / Safe Attachments policy, and who is covered by **nothing** or only by a weak/default policy (using policy priority to resolve the **effective** policy);

• **Preset usage** — whether Standard/Strict presets are enabled and their scope;

• **Bypass hygiene** — a consolidated list of every override that weakens filtering: Tenant Allow/Block List entries, per-policy allowed senders/domains, **transport rules that set SCL -1 or skip filtering**, connection-filter IP allow lists, and disabled protections.

Gap and bypass lists are written explicitly.

Stage 5 — Score against best practice (Assess)

1. Run `SOAMDO-Assess.ps1 -InputDir "SOAMDO-Run – <yyyy-mm-dd> – Assess" -Baseline "<preset + Secure Score>" -OutputCsv "SOAMDO-Scorecard – Tenant – Assess.csv"`. It scores each check **Pass / Partial / Fail / N-A**, assigns a **severity** to each non-pass (bypass findings weighted high), rolls up a **weighted posture score (%)**, and writes the scorecard with the baseline stamped in.

Stage 6 — Generate the findings report (Validate → deliver)

1. Run `SOAMDO-Report.ps1 -InputDir "SOAMDO-Run – <yyyy-mm-dd> – Assess" -Scorecard "SOAMDO-Scorecard – Tenant – Assess.csv" -OutputHtml "SOAMDO-Findings – Tenant – Assess.html"`. It produces the **risk-ranked HTML report** (High → Low, each with area, evidence, affected recipients/count, and a remediation pointer) plus a tracking CSV. Bypass findings surface at the top.

2. **Validate the report reconciles** with the portal: spot-check the top findings — e.g. a transport rule the report flags as setting SCL -1 should read that way in **Mail flow** → **Rules**; a Safe Attachments policy shown as **Monitor** should read Monitor in the portal.

Stage 7 — Review and hand off (Expand)

1. Walk the security owner through the report, especially the **bypass** findings. **Risk-acceptance and remediation priority are their decisions** — annotate accepted exceptions (e.g. a deliberately allow-listed vendor).

2. Hand the ordered backlog to the paired **Remediation Playbook** (pilot-first) for the fixes. Make no changes from this assessment.

3. **Re-run to trend** — same scope file, new dated run folder — so the posture score and the shrinking bypass list are tracked over time.

5. Testing — Security Optimization Assessment: Defender for Office 365

Because this is a **read-only** assessment, "testing" proves two things: the assessor has **read-only** access (and no write), and the **report is accurate** (it reconciles with the Defender portal and Exchange configuration). Run these gates in order; each has an explicit **pass/fail**.

Gate 1 — Read-only access proven (run `SOAMDO-Validate.ps1`)

Procedure: Run `SOAMDO-Validate.ps1` with the assessor identity. **Pass:** Success on all of — `Connect-ExchangeOnline` / `Connect-IPPSSession`; read an anti-phish, Safe Links, Safe Attachments, anti-spam and anti-malware policy; read the **preset** rules; read **transport rules** and the **Tenant Allow/Block List**; run a Graph hunting query; and it confirms **no write role/scope** is present. **Fail:** Any read fails (fix access per R2–R4) **or** a write capability is detected (reduce the assessor to a read-only role — an assessment must not be able to change policy).

Gate 2 — Discovery completeness (run `SOAMDO-Discovery.ps1`)

Procedure: Run discovery; inspect the run folder. **Pass:** Raw outputs exist for every area — anti-spam/malware/phish, Safe Links, Safe Attachments, preset rules, connection filter, DKIM, **transport rules**, **Tenant Allow/Block List**, Secure Score, and `EmailEvents` signals — and policy counts match the portal's Threat policies view. **Fail:** An area file is empty. A missing **transport rules** or **Tenant Allow/Block List** file is the most dangerous — it makes the report look falsely clean. Confirm the read role (R3) and re-run before trusting bypass results.

Gate 3 — Effective-policy and coverage are real (run `SOAMDO-Coverage.ps1`)

Procedure: Run coverage with the **expected mailbox count** (R5). **Pass:** Coverage resolves the **effective** policy per recipient using policy **priority** (not just "a policy exists"), names recipients covered by nothing/weak policy, and produces a consolidated **bypass** list (allow lists + transport rules + connection filter + disabled protections). **Fail:** Coverage reports "policy exists" without resolving priority/recipient scope, or the bypass list omits transport rules — re-check discovery inputs and re-run.

Gate 4 — Scoring is defensible (run `SOAMDO-Assess.ps1`)

Procedure: Run scoring; open the scorecard CSV. **Pass:** Every check has **Pass/Partial/Fail/N-A**, a **severity** on each non-pass, the **baseline name** stamped in, and the weighted posture score computes. MDO-only checks on an EOP-only tenant are **N-A**, not Fail. Bypass findings carry high severity. **Fail:** Checks unscored, severities missing, or MDO-only features scored Fail on an unlicensed tenant (should be N-A findings).

Gate 5 — Report reconciles with the portal (run `SOAMDO-Report.ps1`)

Procedure: Generate the report; spot-check the **top three** findings. **Pass:** Each matches the portal/Exchange config — e.g. a Safe Attachments policy the report shows as **Monitor** reads Monitor in the portal; a transport rule flagged as setting **SCL -1** reads that in Mail flow → Rules; an impersonation-protection gap matches the anti-phish policy. Findings sorted High → Low with evidence and remediation pointers. **Fail:** A spot-checked finding does not match — re-run discovery for a fresh snapshot and confirm scope before delivery.

Gate 6 — Repeatability (trend)

Procedure: Re-run the full sequence against the same scope file into a new dated folder. **Pass:** Runs are comparable (same checks, same baseline); the posture score trends and the bypass list can be shown shrinking as remediation lands. **Fail:** Scope or baseline drifted — pin them in the scope file.

> *These gates test the **assessment**, not the tenant's email security. A low score with a long bypass list is a *successful* assessment — it found the real gaps. The failure conditions are about the assessment's own accuracy and read-only guarantee.*

6. Troubleshooting — Security Optimization Assessment: Defender for Office 365

Common issues when running the read-only assessment, each as **symptom** → **cause** → **fix**. None of these fixes change email-protection configuration — they fix the *assessment run*.

`Connect-ExchangeOnline` or `Connect-IPPSSession` fails

- **Symptom:** The module cannot connect, or the connection prompt cannot complete.

• **Cause:** The ExchangeOnlineManagement module is missing/old, or the assessor lacks a role that can open a session.

• **Fix:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser` (R2); confirm the assessor holds **Global Reader** / **Security Reader** / **View-Only Configuration**; reconnect. Modern auth / MFA is expected — complete the interactive sign-in.

Transport rules or the Tenant Allow/Block List come back empty

• **Symptom:** `SOAMDO-Discovery.ps1` produces empty transport-rule or allow/block-list files, so the bypass section looks clean.

• **Cause:** The read-only role does not include mail-flow / organization configuration read — the most dangerous gap because it hides the highest-value findings.

• **Fix:** Use a role that includes these reads (**Global Reader** generally does — *verify current role-to-cmdlet mapping*), re-run, and do **not** trust bypass results until these files populate. `SOAMDO-Validate.ps1` Gate 1 checks exactly this.

An MDO-only policy type is empty (Safe Links / Safe Attachments / impersonation)

• **Symptom:** Safe Links/Attachments or impersonation settings are absent.

• **Cause:** The tenant is **EOP-only** (no Defender for Office 365 plan) or MDO is licensed on only some mailboxes.

• **Fix:** This is expected — score MDO-only checks as **N-A** and list them as coverage findings (a licensing decision). Confirm plan state in the admin center. *Verify current plan/feature mapping.*

Coverage says a recipient is "uncovered" but a policy clearly exists

• **Symptom:** A user is reported as covered by nothing/weak policy despite a Strict policy existing.

• **Cause:** Policy **priority** and **recipient scope** — the Strict policy is outranked by another policy, or its recipient conditions do not include that user. This is a real finding, not a bug.

• **Fix:** Confirm with the portal's **configuration analyzer** / policy priority. The effective policy is what applies; document it as the finding.

Advanced-hunting `EmailEvents` query is empty or times out

• **Symptom:** The threat-coverage signal is missing.

• **Cause:** `AdvancedHunting.Read.All` not consented, hunting retention exceeded, or the window is too broad.

• **Fix:** Consent the read scope (R4), narrow the time window, or accept the retention limit and note it. *Verify current hunting retention for your licensing.*

Scorecard marks a deliberately allow-listed vendor as a finding

• **Symptom:** An intentional allow-list entry scores as a bypass finding.

- **Cause:** The assessment cannot know an allow-list entry is a deliberate business decision.
- **Fix:** Record it as an **accepted exception** in the review (Stage 7). Risk-acceptance is the customer's decision; annotate so it is not re-flagged each run — but re-confirm it is still needed periodically.

Report findings don't match the portal on spot-check (Gate 5 fail)

- **Symptom:** A top finding reads differently in the portal than in the report.
- **Cause:** Stale discovery data (config changed after the run) or a scope mismatch.
- **Fix:** Re-run `SOAMDO-Discovery.ps1` immediately before reporting, confirm the same scope, and never deliver a report that fails the reconcile spot-check.

Validate flags a write capability present

- **Symptom:** Gate 1 fails specifically on the "no write role" assertion.
- **Cause:** The assessor holds an admin role (e.g. Security Administrator, Exchange Administrator) — over-privileged for an assessment.
- **Fix:** Reduce to a read-only role before running. An assessment must not be able to change policy; this is by design.

7. Best Practices — Security Optimization Assessment: Defender for Office 365

Field-proven guidance for running this assessment cleanly, keeping it honest, and turning the output into action.

Keep it strictly read-only

- **Assess with Global Reader / View-Only Configuration, never an admin role.** If the identity can edit a policy or remove an allow-list entry, the assessment is no longer provably non-disruptive. `SOAMDO-Validate.ps1` fails if a write capability is present — keep it that way.
- **Never remove a bypass mid-assessment.** Pulling a transport rule or allow-list entry the moment you spot it breaks the point-in-time snapshot and can break legitimate mail flow. Record it as a finding; fix it pilot-first in the Remediation Playbook.

Hunt the bypasses — they are the highest-value findings

- **Transport rules are where protection quietly dies.** A single rule setting **SCL -1** or skipping filtering for a domain can neutralize MDO for whole populations. Always enumerate and rank them.
- **The Tenant Allow/Block List and per-policy allow lists accumulate.** Vendors get allow-listed "temporarily" and never removed. Treat broad or stale allow entries as findings.
- **Connection-filter IP allow lists bypass spam filtering entirely** — check them explicitly.
- **A disabled protection is worse than a weak one** — surface any protection turned off.

Score the effective policy, not the intent

• **Resolve priority and recipient scope.** "A Strict anti-phish policy exists" is meaningless if it is outranked or does not cover the right recipients. Always compute the **effective** policy per recipient.

• **Prefer preset Standard/Strict as the reference.** Presets are Microsoft-maintained and drift-resistant; a sprawl of custom policies is a hygiene finding in itself. *Preset behavior evolves — re-confirm each run.*

• **Safe Attachments in Monitor is not protection** — it detonates but delivers. Flag Monitor where Block is expected.

• **Score MDO-only features as N-A on EOP-only tenants**, but list them as coverage findings — it is a licensing decision, not a misconfiguration.

Make the numbers defensible

• **Supply the expected mailbox count** so coverage has a real denominator and "covered by nothing" is visible.

• **Name the baseline and date in the report.** A percentage without its reference is not defensible.

• **Reconcile the top findings against the portal every run** — one wrong finding (especially a bypass) undermines the report's credibility.

Hand off well

• **Lead the review with the bypass findings** — they are the fastest, highest-impact fixes and the ones owners most often did not know existed.

• **Let the customer own risk-acceptance.** Some allow-list entries are deliberate; annotate them as accepted exceptions so they are not re-flagged each run.

• **Re-run on a cadence** and show the bypass list shrinking — that is the clearest proof the program is working.

Protect the output

• The report names exactly who is under-protected and every bypass — store it in the restricted location (R7), share on a need-to-know basis, and never email it broadly.

Where to go next (adjacent catalog areas)

• **Remediation Playbook (SOAREM)** — the paired, pilot-first solution that *closes* these findings (tighten policies, remove stale bypasses), then you re-score.

• **DEFMDOP2** — EOP/MDO build and hardening if the assessment shows the protection design itself is weak.

• **THREATHUNT** — proactive hunting over `EmailEvents` once posture is solid.

• **SOCXDR** — SOC onboarding for the alerts MDO generates. *IR determinations belong to the SOC.*

• **Security Optimization Assessment — Defender for Endpoint / Identity / Cloud Apps / Cloud / Defender Suite** — the sibling assessments; run the **Defender Suite** assessment for a single cross-workload posture score.

8. Deliverables Summary — Security Optimization Assessment: Defender for Office 365

Documentation

Document	Purpose
Executive Summary	The business case — why a licensed MDO is not a tuned one, and what a read-only scored assessment (including hidden bypasses) delivers
1. Solution Overview	What MDO/EOP's protections are (anti-spam/malware/phish, Safe Links, Safe Attachments, preset policies, Tenant Allow/Block List, transport-rule interactions), what "good" looks like, and how the score works
2. Requirements	Solution-specific prerequisites with Verify / Implement-if-missing (category-wide ones live in Global Requirements — Assessments)
Global Requirements (Assessments)	Category-wide prerequisites, published once
3. Implementation	Exact, ordered, read-only steps — validate access, discover every policy/rule, check coverage and bypass hygiene, score, generate the findings report, review, re-run to trend
5. Testing	Read-only and accuracy gates with pass/fail — proves non-disruptive and reconciled with the portal
6. Troubleshooting	Common run issues → cause → fix
7. Best Practices	Keep-it-read-only, hunt-the-bypasses, score-the-effective-policy guidance and where to go next

Automation artifacts (all read-only)

File	What it does
`SOAMDO-Discovery.ps1`	**PowerShell (Exchange Online + Graph), read-only.** Collects every EOP/MDO policy and rule — anti-spam/malware/phish, Safe Links, Safe Attachments, preset rules, connection filter, DKIM — plus **transport rules** and the **Tenant Allow/Block List** for bypass hygiene, and Secure Score / `EmailEvents` signals, into a dated run folder. Changes nothing.
`SOAMDO-Coverage.ps1`	**PowerShell, read-only.** Resolves the **effective** policy per recipient by priority, finds recipients covered by nothing/weak policy against the expected mailbox count, checks preset usage, and produces a consolidated **bypass** list (allow lists + transport rules + connection-filter IPs + disabled protections).
`SOAMDO-Assess.ps1`	**PowerShell, read-only.** Scores each check Pass/Partial/Fail/N-A against the preset + Secure Score baseline, weights bypass findings high, assigns severities, and rolls up a weighted posture score (%). Writes the scorecard with the baseline stamped in.
`SOAMDO-Report.ps1`	**PowerShell, read-only.** Generates the risk-ranked findings report (HTML) sorted High → Low with evidence, affected recipients/counts, and remediation pointers — bypass findings at the top — plus a tracking CSV.
`SOAMDO-Validate.ps1`	**PowerShell, read-only.** Self-check that the assessor can read every policy type **plus transport rules and the Tenant Allow/Block List**, run a hunting query, **and has no write role/scope**. The assessment's read-only guarantee.

What the buyer receives

- This assessment guide as a **Word** document and **PDF**.
- All five read-only PowerShell scripts in a single ZIP — yours to keep and re-run to trend your posture and shrink your bypass list over time.
- A repeatable process following the model: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand** — this package owns **Assess** (read-only); the fixes are the paired Remediation Playbook, done pilot-first.

Delivered as a Complete Solution Package (PDF + Word + scripts).

Outcome

A defensible, point-in-time **posture score** for Defender for Office 365 and a **prioritized, risk-ranked remediation backlog** — including every override and bypass that quietly weakens filtering — the

evidence to fix what matters, in order, plus the scripts to re-score. Risk-acceptance and remediation priority remain the customer's security owners' decisions.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

SOAMDO-Assess.ps1

Purpose: Evaluates the discovery/coverage evidence as checks, each scored Pass / Partial / Fail / N-A against the named baseline (Microsoft preset Standard/Strict + Secure Score, and/or the org standard). Every non-pass gets a severity (High/Medium/Low) and becomes a finding with evidence and a remediation pointer; bypass findings are weighted high. Areas roll up into a weighted posture score (%). MDO-only checks on an EOP-only tenant are scored N-A, not Fail. HOW TO RUN pwsh -File .\SOAMDO-Assess.ps1 -InputDir ".\SOAMDO-Run - 2026-07-11 - Assess" -Baseline "Preset Strict + Secure Score (2026-07, verify)" -OutputCsv ".\SOAMDO-Scorecard - Tenant - Assess.csv" Run SOAMDO-Discovery.ps1 and SOAMDO-Coverage.ps1 first. EXPECTED RESULTS A scorecard CSV + findings.json in the run folder, and a posture score to console. .NOTES White-label. Read-only. Scoring only. Risk-acceptance is the customer's decision. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$InputDir, [string]$Baseline = 'Microsoft preset Standard/Strict + Secure Score (verify current guidance)', [Parameter(Mandatory = $true)] [string]$OutputCsv)

How to run: pwsh -File .\SOAMDO-Assess.ps1 -InputDir ".\SOAMDO-Run - 2026-07-11 - Assess" -Baseline "Preset Strict + Secure Score (2026-07, verify)" -OutputCsv ".\SOAMDO-Scorecard - Tenant - Assess.csv" Run SOAMDO-Discovery.ps1 and SOAMDO-Coverage.ps1 first. EXPECTED RESULTS A scorecard CSV + findings.json in the run folder, and a posture score to console. .NOTES White-label. Read-only. Scoring only. Risk-acceptance is the customer's decision. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$InputDir, [string]$Baseline = 'Microsoft preset Standard/Strict + Secure Score (verify current guidance)', [Parameter(Mandatory = $true)] [string]$OutputCsv)

SOAMDO-Coverage.ps1

Purpose: Turns the raw discovery evidence into the picture that matters: which protections cover which recipients (resolving the EFFECTIVE policy by priority, not just "a policy exists"), who is covered by nothing or only a weak/default policy, whether the Standard/Strict presets are on, and — the highest-value output — a consolidated BYPASS list: Tenant Allow/Block List entries, per-policy allowed senders/domains, transport rules that set SCL -1 or skip filtering, connection-filter IP allow lists, and disabled protections. Names everything explicitly. HOW TO RUN pwsh -File .\SOAMDO-Coverage.ps1 -InputDir ".\SOAMDO-Run - 2026-07-11 - Assess" -ExpectedMailboxCount 850 Run SOAMDO-Discovery.ps1 first. EXPECTED RESULTS A coverage summary + coverage-bypasses.csv and coverage-gaps.csv in the run folder. Read-only. .NOTES White-label. Read-only. Consumes discovery output only; makes no changes. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$InputDir, [int]$ExpectedMailboxCount = 0)

How to run: pwsh -File .\SOAMDO-Coverage.ps1 -InputDir ".\SOAMDO-Run - 2026-07-11 - Assess" -ExpectedMailboxCount 850 Run SOAMDO-Discovery.ps1 first. EXPECTED RESULTS A coverage summary + coverage-bypasses.csv and coverage-gaps.csv in the run folder. Read-only. .NOTES White-label. Read-only. Consumes discovery output only; makes no changes. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$InputDir, [int]$ExpectedMailboxCount = 0)

SOAMDO-Discovery.ps1

Purpose: Builds the raw evidence base the coverage and scoring passes consume. Collects, read-only: anti-spam (hosted content filter) + outbound spam, anti-malware, anti-phish, Safe Links, Safe Attachments policies and their rules; the preset (EOP + ATP) protection policy rules; the connection filter and DKIM config; and — for bypass hygiene — the transport (mail-flow) rules and the Tenant Allow/Block List. Also pulls Secure Score MDO recommendations and an EmailEvents volume signal via Graph advanced hunting. Nothing is changed. HOW TO RUN pwsh -File .\SOAMDO-Discovery.ps1 -ScopeFile ".\SOAMDO-Scope - Tenant - Assess.json" -OutputDir ".\SOAMDO-Run - 2026-07-11 - Assess" Run SOAMDO-Validate.ps1 first. Requires read-only Exchange Online + Graph access. Verify current cmdlet/API coverage and role mapping.* EXPECTED RESULTS A populated run folder with one file per area plus discovery-manifest.json. Read-only — no changes. .NOTES White-label. Read-only. Makes no changes. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$ScopeFile, [Parameter(Mandatory = $true)] [string]$OutputDir)

How to run: pwsh -File .\SOAMDO-Discovery.ps1 -ScopeFile ".\SOAMDO-Scope - Tenant - Assess.json" -OutputDir ".\SOAMDO-Run - 2026-07-11 - Assess" Run SOAMDO-Validate.ps1 first. Requires read-only Exchange Online + Graph access. Verify current cmdlet/API coverage and role mapping.* EXPECTED RESULTS A populated run folder with one file per area plus discovery-manifest.json. Read-only — no changes. .NOTES White-label. Read-only. Makes no changes. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$ScopeFile, [Parameter(Mandatory = $true)] [string]$OutputDir)

SOAMDO-Report.ps1

Purpose: Turns the scorecard, coverage, and bypass list into a deliverable: a risk-ranked HTML report (findings sorted High -> Low with area, description, evidence, and remediation pointer), the headline posture score, the coverage summary, and — surfaced prominently — the override & bypass list. Plus a companion tracking CSV. This is the artifact the security owner reviews and hands to the Remediation Playbook. HOW TO RUN pwsh -File .\SOAMDO-Report.ps1 -InputDir ".\SOAMDO-Run - 2026-07-11 - Assess" -Scorecard ".\SOAMDO-Scorecard - Tenant - Assess.csv" -OutputHtml ".\SOAMDO-Findings - Tenant - Assess.html" Run SOAMDO-Assess.ps1 first. EXPECTED RESULTS An HTML findings report and findings-tracking.csv. Read-only — reads run output only. .NOTES White-label. Read-only. Store output securely — it maps who is under-protected and every bypass. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$InputDir, [Parameter(Mandatory = $true)] [string]$Scorecard, [Parameter(Mandatory = $true)] [string]$OutputHtml, [string]$Title = 'Security Optimization Assessment — Defender for Office 365')

How to run: pwsh -File .\SOAMDO-Report.ps1 -InputDir ".\SOAMDO-Run - 2026-07-11 - Assess" -Scorecard ".\SOAMDO-Scorecard - Tenant - Assess.csv" -OutputHtml ".\SOAMDO-Findings - Tenant - Assess.html" Run SOAMDO-Assess.ps1 first. EXPECTED RESULTS An HTML findings report and findings-tracking.csv. Read-only — reads run output only. .NOTES White-label. Read-only. Store output securely — it maps who is under-protected and every bypass. > [CmdletBinding()] param([Parameter(Mandatory = $true)] [string]$InputDir, [Parameter(Mandatory = $true)] [string]$Scorecard, [Parameter(Mandatory = $true)] [string]$OutputHtml, [string]$Title = 'Security Optimization Assessment — Defender for Office 365')

SOAMDO-Validate.ps1

Purpose: The read-only guarantee of the assessment. Confirms the current identity can read an anti-phish, Safe Links, Safe Attachments, anti-spam and anti-malware policy; the preset security policy rules; the transport (mail-flow) rules and the Tenant Allow/Block List (critical for bypass hygiene); and a

Graph advanced-hunting query — and asserts that NO write role/scope is present. A missing transport-rule / allow-list read is called out specifically because it hides the highest-value findings. HOW TO RUN pwsh -File .\SOAMDO-Validate.ps1 Requires ExchangeOnlineManagement + Microsoft.Graph modules. Prompts for interactive sign-in. Assessor should hold Global Reader / Security Reader / View-Only Configuration only. Verify current role-to-cmdlet mapping and Graph scope names.* EXPECTED RESULTS A PASS/FAIL line per check and an overall verdict. Read-only — makes no changes. .NOTES White-label. Read-only. Makes no changes. Assessment access self-check. > [CmdletBinding()] param()

How to run: pwsh -File .\SOAMDO-Validate.ps1 Requires ExchangeOnlineManagement + Microsoft.Graph modules. Prompts for interactive sign-in. Assessor should hold Global Reader / Security Reader / View-Only Configuration only. Verify current role-to-cmdlet mapping and Graph scope names.* EXPECTED RESULTS A PASS/FAIL line per check and an overall verdict. Read-only — makes no changes. .NOTES White-label. Read-only. Makes no changes. Assessment access self-check. > [CmdletBinding()] param()